

Patient Passport System Security Analysis

Extensive consideration into security is essential when developing and deploying a system that manages valuable and sensitive data such as NHS patient records. The aim of this research is to evaluate the potential security implications of Patient Passports, applying widely used information security models.

Patient Passports plan to store comprehensive patient records and clinician details. The Department of Health and Social Care's guidance for digital and data-driven health technologies outlines that innovative technologies, handling health data, must be in accordance with The Caldicott Principles (1997). These principles will ensure the confidentiality of data at rest in the Patient Passport system. The confidentiality and security of data transferred through the system should also maintain legal standards. Under the Data Protection Act (2018), the NHS has a responsibility to ensure that information is protected from 'unlawful or unauthorised processing, access, loss, destruction or damage' (Data Protection Act, 2018). A data breach compromising patient data confidentiality could result in a loss of confidence in the NHS. In the past, clients of companies and organisations suffering from data breaches have been known to pursue legal action against them as compensation.

If patient records are maliciously accessed and changed, it compromises the validity of the system and in turn - its usefulness. This not only poses a threat to patient data confidence but human life itself. Consider that a patient's medical record is tampered with, they are then given inadequate or unsuitable treatment. This failure has the potential to cause risk to patient health and cause disruption to NHS services. This could occur if (for varying reasons) a disgruntled employee with access to Patient Passports, exploits their position to gain access. As internal dissatisfaction with NHS wages and general employee unhappiness grows, so do the security risks. A recent NHS Staff Survey (NHS Staff Surveys, 2024) found that only 31.23% of staff were satisfied with the level of pay they receive. Although this is an increase compared to recent years, the threat of backlash remains. Insider threats pose serious dangers; IBM highlight a 2022 threat report showing that 'it takes security teams an average of 85 days to detect and contain an insider threat' (IBM, 2023). In the same resource IBM provide guidelines to mitigate the risks of and detect insider threats. One strategy: identity and access management (IAM), involves managing user identities with access to the system ensuring 'the right users and devices can access for the right reasons at the right time'. However, the accessible nature of the Patient Passport system may complicate the effectiveness of this mitigation strategy.

Availability of information and systems is integral to continued operation of NHS services. In May 2017, the NHS was subject to a ransomware attack known as 'WannaCry'. This non-targeted attack is estimated to have infected more than 230,000 computers (Smart, W, 2018). Access to files was restricted via encryption as part of this attack. The result: widespread disruption to NHS services in over one third of trusts in England. Consequently, file unavailability led to the impeded availability of critical healthcare services. Similarly, Dedicated Denial of Service (DDoS) attacks pose a similar threat to availability of health technologies. These attacks are all potential threats that Patient Passports can face once the system is deployed and should be used as guiding markers for developing the security infrastructure of the Patient Passport system.

Authentication technologies threaten system security if not implemented effectively. Often, users will set passwords as something personal and easy to remember. However, this will make it easier for others to gain unauthorised access to their account. The NHS app has already implemented multi-factor authentication requiring a one-time password sent to via text message. Access to the account first requires an NHS number and a password which must be within the parameters of the Password Policy guide. While this enhances security there are common vulnerabilities that will inevitably be faced including phishing and brute

force attacks. It is also worth noting the importance of the balance between security layers and user convenience. Some users may reject the system if accessing it is too complicated.

When considering legal use of patient data another issue arises. Patients must be consulted before their data is used in this new system. A discrepancy in the number of patients who allow their data to be transferred may cause issues; some patients will be on new systems and others, old systems. While 81 per cent of the public said they support the development of a Patient Passport System, agreeing that the convenience outweighs the risks, not everyone is willing to share their data. Only 68 per cent would be happy to share their records with other medical staff (Sylvester, R., Hayward, E. and Lambert, G. , 2024). Furthermore, the Data Protection Act (2018) grants users the right to stop or restrict the processing of their data and under the GDPR, users have the right to be forgotten. Retracted authorisation of information usage must be reviewed often to ensure that medical staff cannot access records that should have been deleted. Serious legal consequences could occur if records are accessed after a request for removal was filed. For those who allow their records to be ported, the system will allow any doctor treating a patient access to their records in GPs, NHS hospitals, pharmacies, or social care settings. Although the aim of this system is to allow anyone treating a patient to access their records, it is still imperative that, as per the Saltzer and Schroeder's Least Privilege Design Principle (1975), users should only be given the essential privileges required to complete their job. The Identity and Access Management strategy will also aid in avoiding the misuse of patient records.

Entrusting users with greater control over their medical data; Patient Passports will grant patients the ability to book appointments, view their full medical history and contact doctors from the NHS app. For this reason, it is important that user actions are monitored to avoid misuse of systems. Additionally, a detailed log of the actions of medical staff within the system will aid inquiries in the event of a security incident.

Applying CIA AAA models will strengthen the security of the patient passport system. It is important to train medical staff on the best practices for maintaining information security, using the system responsibly, and ensure the public are aware of the risks and their responsibilities.

Patient Passport Network Optimisation Analysis

Transport Protocols are used for data transmission across networks, sending data between devices. There are two main types of transport protocols that manage the delivery of packets: User-Datagram Protocol and Transmission Control Protocol. One goal of Patient Passports is the increase of medical care efficiency. Therefore, an efficient networking system is needed. The following outlines the advantages and disadvantages of common Transport Protocols, highlighting which is appropriate for the system.

User-Datagram Protocol (UDP) does not guarantee data delivery as some UDP segments are lost in transmission. UDP is the simpler of the two transport protocols. The main advantage to UDP is that it has a fast transfer rate and low overhead as it does not confirm the connection when sending a packet. In addition, it does not have congestion control, allowing for rapid transfer of data packets. The lack of congestion control is cause of packet loss during high rates of traffic. Despite the lack of communication confirmation checking, UDP can detect errors in segments that are transmitted. While UDP is useful for streaming videos, where packet loss is not detrimental, using UDP for transmission of sensitive and important health records is not valid.

UDP's counterpart, Transmission Control Protocol (TCP) ensures reliable data delivery, with full, in-order packet transmission. In the event there are too many sources for the network to manage the data transmission, congestion control can be used to increase the transmission rate. This increase never exceeds the point where packets will be lost. Another method that guarantees reliable data transfer is the "three-way handshake" that establishes a secure connection between client and server. In the event of a connection timeout or error, TCP will

retransmit the data starting from the last received segment. TCP utilises connection-oriented protocol to confirm in-order transmission. Once client-server connection has been established, the connection-oriented protocol establishes a logical connection between the two hosts before data transfer begins. All these processes ensure no packets are missed and they are in the right order. The trade-off for TCP's reliability is that it takes longer to transmit data than its counterpart, UDP. Partially because TCP segments have a header length of 20 bytes, compared to UDP's 8 bytes header length. This delay is reduced by not starting transmission over entirely and instead utilising data retransmission.

In the scenario of patient passports, medical records are sent from the server to the device that's requesting information. A full record should be available when clinicians request access since every packet of the data being accessed could be important. Reasonably, a protocol that is capable of full data transmission should be implemented. For this reason, the Transmission Control Protocol is the right choice for data transfer in Patient Passports. Out-of-order data or data that has not been fully received would disrupt the delivery of healthcare. The security of these two protocols is also an important consideration here. Since TCP monitors transmitted data packets, the risk of malicious data is lessened as systems can be implemented to flag harmful packets.

As identified, the main disadvantage of TCP is the network transmission delay referring to the time it takes to receive data over a network. Software tools can help identify points in the network which may be acting as a bottleneck – slowing down the rate of data transfer. Packet analysers like Wireshark can be used to monitor the network traffic through capturing and analysis. Network monitoring tools can help identify the bottleneck by detecting congestion, packet losses and latency.

Terminal commands for ping and traceroute can identify delays or errors in the network. The ping command checks if a host is reachable by sending an echo request. Using the ping command to measure round-trip time (RTT) may reveal hops with high latency. Showing areas in the network that are experiencing delays, a potential bottleneck. The traceroute command gives a more detailed insight into the route that packets take. Packets are sent through the network. Each time a new packet is sent, its time to live (TTL) is increased slightly. By analysing the messages sent back, a detailed list of routers accessed can be made. Using this information, routing issues can be identified within the network.

Reference List

Data Protection Act 2018, c.12, [online] Legislation.gov.uk. Available at: <https://www.legislation.gov.uk/ukpga/2018/12/contents/enacted> [Accessed 9 Mar. 2024].

Department of Health and Social Care (2018) Code of conduct for data-driven health and care technology, [online] GOV.UK. Available at: <https://www.gov.uk/government/publications/code-of-conduct-for-data-driven-health-and-care-technology/initial-code-of-conduct-for-data-driven-health-and-care-technology> [Accessed 9 Mar. 2024].

General Data Protection Regulation (GDPR) - Right to erasure ('right to be forgotten') | Art 17, [online] General Data Protection Regulation (GDPR). Available at: <https://gdpr-info.eu/art-17-gdpr/> [Accessed 9 Mar. 2024].

IBM (2023) What are insider threats? [online] [www.ibm.com](https://www.ibm.com/topics/insider-threats). Available at: <https://www.ibm.com/topics/insider-threats> [Accessed 9 Mar. 2024].

McDonald, H. (2023) Patients are taking legal action against HCA Healthcare after the company suffered a major hack. News Channel 5 Nashville (WTVF), [online] 18 Jul.

Available at: <https://www.newschannel5.com/news/patients-are-taking-legal-action-against-hca-healthcare-after-the-company-suffered-a-major-hack> [Accessed 9 Mar. 2024].

National Data Guardian (2020) The Eight Caldicott Principles, [online] National Data Guardian. Available at: https://assets.publishing.service.gov.uk/media/5fcf9b92d3bf7f5d0bb8bb13/Eight_Caldicott_Principles_08.12.20.pdf [Accessed 9 Mar. 2024].

NHS Digital (2021) Password Policy Guide, [online] NHS Digital. Available at: <https://digital.nhs.uk/about-nhs-digital/corporate-information-and-documents/password-policy-guide---example-guide> [Accessed 9 Mar. 2024].

NHS Staff Surveys (2024) NHS Staff Survey 2023 National results briefing, [online] NHS Staff Survey, p.21. Available at: <https://www.nhsstaffsurveys.com/static/3b9bd4686a7075ed186a377e918c117b/National-Results-Briefing-2023.pdf> [Accessed 9 Mar. 2024].

Smart, W. (2018) Lessons Learned review of the WannaCry Ransomware Cyber Attack, [online] pp.10–14. Available at: <https://www.england.nhs.uk/wp-content/uploads/2018/02/lessons-learned-review-wannacry-ransomware-cyber-attack-cio-review.pdf> [Accessed 10 Mar. 2024].

Sylvester, R., Hayward, E. and Lambert, G. (2024) Public back ‘patient passports’ to share medical records with any doctor. www.thetimes.co.uk, [online] 4 Feb. Available at: <https://www.thetimes.co.uk/article/nhs-data-shared-freely-times-health-commission-bqhrfwh83> [Accessed 9 Mar. 2024].

Wikipedia Contributors (2019) Principle of least privilege, [online] Wikipedia. Available at: https://en.wikipedia.org/wiki/Principle_of_least_privilege [Accessed 9 Mar. 2024].

Wikipedia Contributors (2023) Saltzer and Schroeder’s design principles, [online] Wikipedia. Available at: https://en.wikipedia.org/wiki/Saltzer_and_Schroeder%27s_design_principles#:~:text=Least%20privilege%3A%20Every%20program%20and [Accessed 9 Mar. 2024].